

Thesis Threat Model Report — Scenario 2

LLM-Integrated Secure File Management System | Multi-Framework Audited Threat Dataset

105

RAW FINDINGS

8

VALIDATED THREATS

97

DUPLICATES EXCLUDED

100.0%

GROUNDING RATE

7.6%

THREAT PRECISION

ID	Element	STRIDE	Framework Mappings	Threat Description & Evidence	Mitigation Strategy	CVSS	Stage
T2.01	P2 — File Management Service DF5: Authenticated File Access Request	Elevation of Privilege	ATT&CK: T1078: Valid Accounts (BOLA / IDOR) OWASP: A01:2021 – Broken Access Control ATLAS: – LLM Top10: – LINDDUN: Disclosure of Information ML Sec: –	Broken Object-Level Authorization (BOLA/IDOR): Attacker supplies an unauthorized file ID in DF5, and P2 fails to enforce ownership checks against DS2, enabling unauthorized file access. Evidence: P2 is the primary enforcement point for file authorization and must verify user ownership against DS2 before querying DS1.	Enforce mandatory, fail-closed authorization checks associating user ID, object ID, and action against DS2 on every access request.	8.1 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	Design
T2.02	P2 — File Management Service DF2: Uploaded File + Metadata / DF3: Validated File Storage Request	Tampering	ATT&CK: T1059: Command and Scripting Interpreter (Path Traversal) OWASP: A01:2021 – Broken Access Control / Path Traversal ATLAS: – LLM Top10: – LINDDUN: Non-compliance ML Sec: –	Path traversal or filename manipulation during upload validation (DF2) allows an attacker to overwrite sensitive files or write outside designated storage directories in DS1. Evidence: P2 receives user-provided filenames and metadata across TB1 and writes validated files to DS1.	Sanitize user-supplied filenames, generate server-managed random UUIDs for storage keys, and validate extensions/MIME types.	8.8 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	Implementation
T2.03	P2 — File Management Service DF1: File Upload Request / DF2: Uploaded File + Metadata	Denial of Service	ATT&CK: T1499: Endpoint Denial of Service OWASP: A05:2021 – Security Misconfiguration ATLAS: – LLM Top10: – LINDDUN: Unawareness ML Sec: –	Storage exhaustion via unbounded file uploads or decompression bombs, consuming server disk and memory capacity. Evidence: P2 processes file uploads from Zone A into DS1. Lack of quotas or size validation leads to resource exhaustion.	Enforce strict per-user storage quotas, maximum upload size caps, and streaming file inspection.	6.5 AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H	Implementation
T2.04	P3 — AI File Assistant DF18: Prompt + Approved Context	Tampering	ATT&CK: T1059: Command and Scripting Interpreter OWASP: A03:2021 – Injection ATLAS: AML.T0051: LLM Prompt Injection (Indirect) LLM Top10: LLM01: Prompt Injection LINDDUN: Non-compliance ML Sec: ML01: Adversarial Robustness & Input Manipulation	Indirect prompt injection: Uploaded document content contains malicious instructions that hijack the assistant's behavior when processed by P3/P4/EE2. Evidence: P3 retrieves document content and combines it with user questions into prompt payload DF18 sent to P4/EE2. Explicit requirement 16 addresses indirect prompt injection.	Enforce structural prompt isolation (delimiters) separating system instructions from document text, and apply output safety filters.	5.4 AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N	Design
T2.05	DF13 — Authorized Context Request DF13: Authorized Context Request / DF16: Authorized Document Retrieval	Information Disclosure	ATT&CK: T1078: Valid Accounts OWASP: A01:2021 – Broken Access Control ATLAS: AML.T0024: LLM Data Leakage LLM Top10: LLM06: Sensitive Information Disclosure LINDDUN: Disclosure of Information ML Sec: ML09: Data Leakage	Bypassing authorization workflow: If P3 directly queries DS1 or P2 omits DS2 verification on context retrieval, unauthorized document text is processed by AI assistant. Evidence: Architecture specifies mandatory authorization path: P3 -> P2 -> DS2 -> DS1 -> P2 -> P3. Bypassing P2/DS2 violates requirement 12 & 13.	Strictly enforce the architectural path requiring P2 to verify user authorization against DS2 before returning document context to P3.	6.5 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	Design

ID	Element	STRIDE	Framework Mappings	Threat Description & Evidence	Mitigation Strategy	CVSS	Stage
T2.06	DF19 — Prompt + Approved Context DF19: Prompt + Approved Context -> EE2	Information Disclosure	ATT&CK: T1552: Unsecured Credentials / Sensitive Data OWASP: A01:2021 – Broken Access Control ATLAS: AML.T0024: LLM Data Leakage LLM Top10: LLM06: Sensitive Information Disclosure LINDDUN: Disclosure of Information ML Sec: ML09: Model Data Leakage	Unredacted transmission of sensitive document PII or credentials across TB4 to the third-party External LLM Provider. Evidence: P4 transmits DF19 across TB4 to EE2. Requirement 18 mandates that sensitive document information sent to external LLM must be minimized.	Apply context minimization, PII redaction, and DLP scanning on document text prior to transmitting prompt payloads.	6.5 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	Implementation
T2.07	P1 — Web Frontend Interface DF10: Retrieved File / DF23: Answer Display	Tampering	ATT&CK: T1059.007: JavaScript (Stored XSS) OWASP: A03:2021 – Injection (XSS) ATLAS: AML.T0054: LLM Output Manipulation LLM Top10: LLM02: Insecure Output Handling LINDDUN: Disclosure of Information ML Sec: ML06: AI Supply Chain & Output Integrity	Stored XSS via downloaded files or rendered AI answers: malicious scripts in uploaded documents or generated text execute in victim browser context. Evidence: P1 presents retrieved files (DF10) and answers (DF23) to EE1. Requirement 11 specifies that retrieved files must not be treated as safe active content.	Set `Content-Disposition: attachment` on file downloads, sanitize rendered AI text using DOMPurify, and enforce strict CSP.	7.3 AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N	Implementation
T2.08	DS2 — User / Permission Database DF6: Authorization Verification Request / DF14: Authorization Verification	Denial of Service	ATT&CK: T1499: Endpoint Denial of Service OWASP: A05:2021 – Security Misconfiguration ATLAS: – LLM Top10: – LINDDUN: Unawareness ML Sec: –	Database lockup or availability failure in DS2 causes all authorization checks to fail closed, resulting in complete denial of service for file access and AI assistance. Evidence: DS2 is the authoritative source for permissions. Requirement 10 dictates that authorization failure or unavailability must fail closed.	Configure connection pooling, query performance indexes, read-replicas, and optimized authorization query caching.	7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	Implementation